Pentest local

Metodología de las pruebas de seguridad — Ronda 3

Equipo SOS Clinic

22 de octubre de 2026

1 Objetivo y alcance

Re-verificar los 25 hallazgos de la ronda 2 y comprobar la postura de seguridad actual del sistema: autenticación, autorización por rol, JWT, CORS, cabeceras, entrada de datos, IDOR, límites de intentos y XSS almacenado.

Todo el tráfico se dirigió a `localhost` (gateway 8080, servicios 8081–8084 y 8088, frontend 5500). No se atacó infraestructura externa. Las pruebas se ejecutaron sobre el seed canónico con cuentas reales de rol y cuentas temporales para los casos de fuerza bruta.

2 Entorno

- Stack completo levantado con `04. levantar-sistema.bat`.
- PostgreSQL con el seed de 9 cuentas, 24 pacientes y 30 episodios.
- Ocho roles disponibles: administrador, seguridad, coordinación, médico, triage, recepción, lista de espera y auditor.
- Navegador Chromium controlado para la prueba de XSS.

3 Diseño de las pruebas

3.1 Autenticación y JWT

- Token firmado con un secreto distinto, token con `alg=none` y token real con el payload modificado (perfil elevado a administrador).
- Peticiones sin token al gateway y a los puertos directos de cada servicio, para comprobar que la validación no depende solo del gateway.

3.2 Matriz de autorización

Se probaron 11 endpoints con los 8 roles (88 combinaciones), verificando el código esperado en cada caso: lecturas clínicas, escrituras, administración, auditoría, aprobación de cuentas, analítica y agente IA.

3.3 Configuración

- Preflight CORS con origen permitido y con `evil.local`.
- Cabeceras de seguridad del gateway y del frontend.
- CSP, traversal en el servidor estático y exposición de Actuator.

3.4 Datos y lógica

- Mass assignment en pacientes y signos vitales (campos de servidor enviados por el cliente).
- Inyección SQL en búsqueda por cédula y cédula exacta.
- JSON malformado, referencias inexistentes y episodios inexistentes.
- IDOR horizontal: acceso a episodios, pacientes e historias de otros usuarios con un rol clínico.

3.5 Límites de intentos y 2FA

- Challenge 2FA válido, reutilización y propósito incorrecto.
- Cinco códigos 2FA erróneos y bloqueo posterior.
- Cinco contraseñas erróneas y bloqueo posterior.
- Enumeración de usuarios en login y recuperación de clave.

3.6 XSS almacenado

Se creó una cuenta temporal sin 2FA y un paciente con el nombre `<img src=x onerror=window.__xss=1>`. Un navegador real abrió `pacientes.html`, `lista-espera.html` y `seguimiento.html?idRegistro=37`; se comprobó la variable `window.__xss`, la presencia de `<img>` inyectadas, el texto visible y los diálogos.

4 Procedimiento y limpieza

1. Login de las 8 cuentas del seed completando el 2FA con un código temporal insertado en la base (no se leen correos).
2. Ejecución de las comprobaciones con `pentest_local.py`.
3. Creación de usuarios temporales únicos por corrida para evitar el bloqueo en memoria del limitador.
4. Limpieza de usuarios, códigos, tokens, tomas y pacientes de prueba al finalizar, incluso si una sección falla.
5. Prueba de XSS con `pentest_xss.py`, navegador y limpieza posterior.

El limitador de login/2FA es en memoria. Repetir el pentest en menos de 10 minutos devuelve 429; en local se reinició `ms-seguridad` para limpiar la ventana antes del pase final.

5 Criterios y salvaguardas

- **PASS** si el comportamiento coincide con la matriz esperada o con la remediación de la ronda 2.
- **FAIL** si hay una desviación de seguridad o un error no controlado.
- **WARN** para residuales aceptados o riesgos de mínimo privilegio.
- No se imprimen credenciales, tokens ni contenido de `.env`.
- Los correos de prueba llegan a la bandeja `pruebasosclinic@gmail.com`; no se usan datos reales.
- No se ejecutan ataques de denegación de servicio ni fuerza bruta masiva.

6 Limitaciones

- El IDOR se cierra por rol, no por propiedad del episodio; es un residual aceptado y se documenta como tal.
- No se probó revocación de JWT (el sistema no la tiene).
- No se evaluaron ataques de red, contenedores ni cadena de suministro más allá de Trivy.
- La prueba de XSS cubre tres páginas; no es un barrido exhaustivo de todas las vistas.

7 Reproducción

```
python seguridad/pruebas/pentest_local.py
python seguridad/pruebas/pentest_xss.py prepare
# abrir pacientes/lista de espera con la cuenta temporal
python seguridad/pruebas/pentest_xss.py cleanup
```